ApexFlow Technologies – Enterprise Security & Architecture

Document Version: 4.2 | Classification: Confidential / External Client Review | Date: January 2026

1. Architecture & Multi-Region Hosting

ApexFlow Enterprise Suite v4.2 is a cloud-native B2B workflow automation platform designed for global enterprises. The architecture is deployed across multi-region high-availability clusters in AWS US-East (Northern Virginia) and AWS EU-Central (Frankfurt).

The platform operates an active-active failover model with automated multi-zone replication, delivering high resiliency and zero single points of failure.

2. Authentication, Single Sign-On (SSO) & SCIM

ApexFlow supports turnkey enterprise Single Sign-On (SSO) via SAML 2.0 and OpenID Connect (OIDC). Verified turnkey identity providers include Okta, Microsoft Entra ID (Azure AD), Google Workspace, PingFederate, and CyberArk.

- **User Provisioning:** Just-In-Time (JIT) provisioning and SCIM 2.0 directory synchronization for automated user on-boarding, role mapping, and instantaneous de-provisioning upon employee offboarding.
- **Multi-Factor Authentication (MFA):** MFA is enforced by default, supporting FIDO2 / WebAuthn, hardware security keys (YubiKey), and TOTP authenticator apps.
- **Role-Based Access Control:** Granular RBAC supporting custom enterprise permission tiers (Global Admin, Department Head, Approver, Analyst, Auditor, Read-Only).

3. Data Encryption & Tenant Isolation

All enterprise customer data is strictly segregated using isolated logical tenant schemas, database-level Row-Level Security (RLS), and dedicated cryptographic tenant partition keys.

- **Encryption at Rest:** All production databases, cache layers, and object storage volumes are encrypted using AES-256 with Customer-Managed Keys (BYOK) via AWS KMS. Master encryption keys are rotated automatically every 365 days.
- **Encryption in Transit:** TLS 1.3 is enforced with HTTP Strict Transport Security (HSTS) on all external web, mobile, and API endpoints. Internal service-to-service microservice communications require mutual TLS (mTLS) with SPIFFE identity certificates.

4. Data Retention, Backup & Disposal

Customer operational data is retained for 90 days following subscription termination by default, after which a certified cryptographic wipe conforming to NIST SP 800-88 Rev 1 is executed with an auditable certificate of destruction provided upon request.

- **Automated Backups:** Database snapshots are captured every 24 hours with continuous write-ahead logging (WAL), retained for 35 days, encrypted with AES-256.
- **Cross-Region Replication:** Daily encrypted backups are replicated to an off-site secondary disaster recovery region.

5. Compliance Certifications & Audits

ApexFlow maintains rigorous third-party audited compliance certifications:

• **SOC 2 Type II:** Annual audit conducted by Ernst & Young covering Security, Availability, and Confidentiality trust service criteria. Latest report issued November 2025.

• **ISO Certifications:** Certified under ISO/IEC 27001:2022 (Information Security Management) and ISO/IEC 27701:2019 (Privacy Information Management).

• **Privacy Regulations:** Fully compliant with EU General Data Protection Regulation (GDPR) and California Consumer Privacy Act (CCPA/CPRA). Standard Contractual Clauses (SCCs) and Data Processing Agreements (DPA) are executed for all enterprise engagements.

• **Healthcare Compliance:** Compliant with HIPAA Security & Privacy Rules; ApexFlow signs standard Business Associate Agreements (BAAs) for covered entities.

6. SLAs, Availability & Disaster Recovery

• **Monthly Uptime Guarantee:** ApexFlow guarantees 99.95% monthly application uptime under our Enterprise SLA, backed by tiered financial service credits for any downtime.

• **Recovery Time Objective (RTO):** Guaranteed RTO of less than 1 hour in the event of an infrastructure or regional disaster.

• **Recovery Point Objective (RPO):** Guaranteed RPO of less than 15 minutes across all customer transactional data stores.

• **DR Simulations:** Disaster recovery simulations and table-top exercises are performed bi-annually with documented executive post-mortems.

7. Enterprise APIs, Webhooks & Rate Limiting

• **REST & GraphQL:** ApexFlow provides a complete RESTful API compliant with OpenAPI 3.1 specifications as well as a GraphQL query interface.

• **Rate Limits:** Standard enterprise API quotas allow up to 10,000 requests per minute per tenant, governed by a token-bucket algorithm with standard HTTP 429 Retry-After response headers.

• **Webhooks & Events:** Outbound webhook notifications with HMAC-SHA256 signature verification allow real-time event streaming to enterprise Slack, Jira, ServiceNow, and custom webhook endpoints.